

Testing Results

1. Overview

This document summarizes the security testing performed during the **Web Application Security Review & Vulnerability Analysis** project. Testing was conducted in an authorized and isolated VMware laboratory environment using Kali Linux, Metasploitable 2, and the Damn Vulnerable Web Application (DVWA).

The assessment focused on reconnaissance, service enumeration, web application mapping, authentication, session management, web server configuration, directory enumeration, cross-site scripting, and SQL injection.

2. Testing Environment

Component	Details
Attacker / Testing System	Kali Linux
Target System	Metasploitable 2
Web Application	DVWA
Virtualization	VMware Workstation
Network Type	Host-Only Network
Target IP	192.168.23.129
Testing Purpose	Authorized Security Assessment

3. Host Discovery

Tool

Nmap

Command

```
nmap -sn 192.168.23.0/24
```

Result

The host discovery scan identified active systems on the authorized laboratory network. The target system 192.168.23.129 was identified as an active host and selected for further assessment.

Status

Completed

4. Service and Version Enumeration

Tool

Nmap

Command

```
nmap -sV 192.168.23.129
```

Result

The scan identified multiple services running on the target. Of particular relevance to this web application assessment were:

- Port 80 – Apache HTTP Server 2.2.8
- Port 8180 – Apache Tomcat/Coyote

The identified HTTP services were selected for further web security analysis.

Status

Completed

5. Web Application Identification

Application

Damn Vulnerable Web Application (DVWA)

Result

The DVWA application was identified and accessed through the browser using the authorized target system. The application contained several security testing modules, including:

- Brute Force
- Command Execution
- CSRF
- File Inclusion
- SQL Injection
- SQL Injection (Blind)
- File Upload
- XSS Reflected
- XSS Stored
- DVWA Security

The DVWA security level was configured to **Low** for controlled laboratory testing.

Status

Completed

6. Burp Suite HTTP Traffic Analysis

Tool

Burp Suite

Result

Burp Suite was configured as an intercepting proxy between Firefox and the DVWA application.

HTTP history was reviewed to observe:

- HTTP methods
- URLs
- Request parameters
- Headers
- Cookies
- Session-related information

Actual session values were not included in the documented evidence.

Status

Completed

7. Authentication Testing

Test

Controlled valid and invalid authentication attempts were performed against the DVWA Brute Force module.

Result

A valid laboratory credential was accepted successfully, while an intentionally incorrect password resulted in an authentication failure.

The testing was limited to controlled manual attempts and did not involve automated password attacks.

Finding

Authentication behavior was reviewed, but no specific authentication vulnerability was confirmed during the limited test.

Status

Completed – No specific vulnerability confirmed

8. Session Management Review

Tool

Burp Suite

Result

HTTP requests were reviewed for session-related cookies and their security attributes.

The assessment considered protections such as:

- Secure
- HttpOnly
- SameSite

Actual session identifiers were excluded from screenshots and documentation.

Finding

Session management was reviewed as part of the assessment. No specific session-management vulnerability was confirmed during the limited review.

Status

Completed – Informational

9. Web Server Enumeration

Tool

Nikto

Command

```
nikto -h http://192.168.23.129
```

Key Observations

Nikto identified several server configuration and information-disclosure issues, including:

- Apache HTTP Server 2.2.8
- PHP 5.2.4
- Directory indexing
- Accessible `phpinfo.php`
- Exposed phpMyAdmin resources
- HTTP TRACE enabled
- Missing recommended security headers
- Accessible documentation/test-related resources

Finding

The web server contains outdated software and several hardening weaknesses that may increase the attack surface.

Risk

High for outdated components; Medium for several configuration weaknesses

Status

Completed

10. Directory and Resource Enumeration

Tool

Gobuster

Command

```
gobuster dir -u http://192.168.23.129 -w  
/usr/share/wordlists/dirb/common.txt
```

Key Results

The enumeration identified resources including:

- index.php
- index
- phpinfo.php
- phpinfo
- phpMyAdmin
- test
- twiki
- dav

Several restricted resources returned HTTP 403 responses, including:

- .htaccess
- .htpasswd

- `cgi-bin`
- `server-status`

Finding

Exposed administrative, development, documentation, and configuration-related resources may increase the attack surface and disclose information about the server environment.

Risk

Medium

Status

Completed

11. Reflected XSS Testing

Tool

DVWA

Test Input

A controlled JavaScript payload was submitted to the Reflected XSS functionality.

Result

The browser did not execute the supplied JavaScript and no XSS popup was observed.

A normal text input was reflected successfully, confirming that the input was processed by the application, but the controlled JavaScript payload was not executed.

Finding

Reflected XSS was not confirmed during testing.

Status

Completed – Not Confirmed

12. Stored XSS Testing

Tool

DVWA

Test

Normal text was first submitted to confirm that the application stored and displayed messages.

A controlled JavaScript test payload was subsequently submitted.

Result

The application did not execute the supplied JavaScript and no XSS popup was observed.

Finding

Stored XSS was not confirmed during testing.

Status

Completed – Not Confirmed

13. SQL Injection Testing

Tool

DVWA

Baseline Test

User ID:

1

The application returned the corresponding user record.

Controlled Test

A controlled SQL injection test using:

1' OR '1'='1

was performed.

Result

The response continued to return only the original user record. No evidence of expanded query results or successful SQL manipulation was observed.

Finding

SQL Injection was not confirmed during testing.

Status

Completed – Not Confirmed

14. File Upload Testing

Tool

DVWA

Result

The File Upload functionality was reviewed, but a complete controlled file-upload security test was not completed during this assessment.

Therefore, no file-upload vulnerability is reported as a confirmed finding.

Status

Not Completed

15. Overall Testing Summary

Test Area	Tool	Result
Host Discovery	Nmap	Completed
Service Enumeration	Nmap	Completed
Application Mapping	Browser / DVWA	Completed

HTTP Traffic Analysis	Burp Suite	Completed
Authentication Review	DVWA	No specific vulnerability confirmed
Session Review	Burp Suite	Informational
Web Server Enumeration	Nikto	Security weaknesses identified
Directory Enumeration	Gobuster	Resources identified
Reflected XSS	DVWA	Not confirmed
Stored XSS	DVWA	Not confirmed
SQL Injection	DVWA	Not confirmed
File Upload	DVWA	Not completed

16. Key Security Observations

The most significant security observations identified during the assessment were:

1. Outdated Apache HTTP Server and PHP versions.
2. Exposure of phpMyAdmin resources.
3. Directory indexing enabled on multiple directories.
4. Exposure of `phpinfo.php`.
5. HTTP TRACE functionality enabled.
6. Missing recommended HTTP security headers.
7. Exposure of development, documentation, and test-related resources.

These observations were used for the OWASP Top 10 mapping and risk assessment.

17. Testing Limitations

The assessment was performed against an intentionally vulnerable laboratory application and was limited to the defined project scope.

The following limitations apply:

- Testing was performed only within an isolated VMware host-only network.
- No production systems were tested.
- No destructive testing was performed.
- No automated password attacks were conducted.
- File Upload security testing was not completed.
- XSS and SQL Injection were tested but not confirmed as exploitable based on the observed responses.

18. Conclusion

The testing successfully demonstrated a structured web application security assessment process using industry-relevant tools and methodologies.

The assessment identified several server-side configuration and information-disclosure weaknesses, particularly outdated software, exposed administrative resources, directory indexing, `phpinfo.php`, HTTP TRACE, and missing security headers.

The results were documented and mapped to relevant OWASP Top 10 categories. Recommended remediation measures are provided separately in the security recommendations documentation.